

Password Policy

wiki/security/password-policy · Updated 2022-06-11 · Owner: Security, IT

Scope

This policy defines password requirements for all employee accounts at Northwind. It applies to every system that authenticates against the corporate identity provider. It is maintained by the Security and IT teams.

Strong account hygiene is one of the cheapest and most effective defences we have against account takeover. Everyone is expected to follow this policy.

Why passwords matter

Most breaches start with a compromised credential. A single reused or guessable password can give an attacker a foothold that spreads across systems. The requirements below exist to make that first step as hard as possible.

Rotation

All employees must rotate their account passwords every 90 days. The identity provider enforces this automatically and will prompt you as the deadline approaches.

- You will receive reminders starting ten days before expiry.
- Failure to rotate within the window will lock your account until IT resets it.

- A locked account requires a verified identity check before it is restored.

Planning around rotation

Do not wait until the last day to rotate. If you are travelling or on leave when your password expires, your account will lock and you will need IT to reset it. Rotate before you go.

Composition requirements

Passwords must meet the following minimum requirements:

- At least 10 characters in length.
- Include at least one number and one symbol.
- Not reuse any of your last 5 passwords.
- Not contain your username, your name, or common dictionary words.

Choosing a strong password

Longer is stronger. A memorable passphrase made of several unrelated words is both easier to remember and harder to crack than a short string of substitutions. Avoid predictable patterns such as appending the current year or season, and never base a password on information that is public about you.

Password managers

We encourage using an approved password manager. It lets you use a long, unique password for every system without having to remember them, which is far safer than reusing one password everywhere.

Multi-factor authentication

Passwords alone are not sufficient. All accounts must have a second factor enabled.

- Prefer an authenticator app or hardware key over SMS where available.
- Register a backup factor in case your primary device is lost.
- Never approve a prompt you did not initiate; report unexpected prompts to Security.

Losing your second factor

If you lose your second-factor device, contact IT for a verified reset and register a new factor immediately. This is why a backup factor matters: without one, losing your device locks you out.

Account lockout and recovery

After several failed sign-in attempts your account is temporarily locked to slow down guessing attacks. If you are locked out, wait for the cool-down period or contact IT for a verified reset. Recovery always requires confirming your identity.

Handling compromise

If you believe your password has been exposed, change it immediately and notify the Security team. Do not wait for the next rotation deadline. Report any phishing attempts that targeted your credentials so the team can block the source.

Recognising phishing

Be suspicious of any message that creates urgency and asks you to sign in through a link. Check the address before entering credentials, and when in doubt, navigate to the system directly rather than following a link.

Worked example

An employee receives a reminder that their password expires in a week. They open their password manager, generate a new long passphrase that meets the composition rules and has not been used before, update it in the identity provider, and confirm their second factor still works. The whole thing takes two minutes and their account never locks.

Frequently asked questions

How often must I change my password? Every 90 days under this policy.

Can I reuse an old password? No, not any of your last five.

What happens if I miss the deadline? Your account locks until IT performs a verified reset.

Common mistakes

- Waiting until the expiry day and locking out while travelling.
- Incrementing a number on the end of the same base password every cycle.
- Reusing a work password on a personal site.

- Approving an unexpected second-factor prompt out of habit.

Enforcement

Compliance is monitored centrally. Repeated policy violations are escalated to your manager. Exceptions require documented approval from the Security team.

Related documents

See the Updated Security Standards for the current direction of our authentication guidance, the VPN Access guide for remote credentials, and the Onboarding Checklist for first-week setup.

Password managers and shared accounts

An approved password manager is the single most effective way to meet this policy comfortably. It generates and stores a long, unique password for every system so you never reuse one or have to remember it.

- Use the approved password manager for all work accounts.
- Protect the manager itself with a strong passphrase and a second factor.
- Avoid shared accounts; where one is unavoidable, manage its credential through the approved tool and

rotate it when a member leaves.

Shared logins undermine accountability because you cannot tell who did what. Prefer individual accounts with appropriate access wherever the system supports them.